

Task 15

Please find below your next **intermediate-level AWS task**, focused on **API Gateway security, monitoring, and automation**.

This task is designed to simulate a **real-world production API scenario**, where APIs must be secured, monitored, and automatically audited without manual intervention.

Build a secure and monitored AWS API Gateway setup that can:

- Detect unauthorized or abnormal API usage
- Log and analyze API traffic
- Automatically notify the team when suspicious activity occurs

Problem Statement

“Our API is exposed publicly.

We need an automated way to:

- Secure the API
- Monitor traffic patterns
- Detect abnormal usage (high requests, unauthorized access)
- Notify the team automatically with relevant details”

Architecture

API Gateway

↓

Lambda Backend / Mock Integration

↓

CloudWatch Logs & Metrics

↓

Usage & Error Analysis

↓

SNS / Email Notification

Task Requirements

1. API Gateway Setup

- Create a **REST API** in API Gateway
- Create the following endpoints:
 - GET /health
 - POST /data
- Backend can be:
 - AWS Lambda (preferred), or
 - Mock integration

2. API Security

Implement **at least one** of the following:

- API Key-based authentication
- IAM authorization
- Lambda Authorizer

Ensure:

- Unauthorized requests are blocked
- Proper HTTP status codes are returned

3. Throttling & Rate Limiting

- Configure:
 - Request rate limits
 - Burst limits
- Protect the API from abuse
- Verify throttling by sending multiple rapid requests

4. Monitoring & Logging

- Enable:
 - CloudWatch execution logs
 - Access logs
- Capture:
 - Request count
 - Error rate (4XX / 5XX)
 - Latency

5. Abnormal Activity Detection (Core Task)

Create a **Lambda function (Python)** that:

- Reads API Gateway metrics from CloudWatch
- Detects:
 - Sudden spike in request count
 - High number of 4XX or 5XX errors
- Uses thresholds such as:
 - Requests > 2× daily average
 - Error rate > 10%

6. Notification

- Configure **SNS email notifications**
- Alert message must include:
 - API name
 - Endpoint
 - Metric breached (traffic / error rate)
 - Timestamp
 - Suggested action

7. Scheduling

- Trigger monitoring Lambda:
 - Every 5 or 15 minutes
- Use **Amazon EventBridge**
- Manual execution is not allowed

Test Scenario (Mandatory)

To validate the solution:

- Send a high number of requests using Postman or curl
- Trigger throttling or error responses
- Verify that the alert email is received

Please attach this necessary requirement Screenshot on Deliverables mail:

- API Gateway configuration screenshots
- Lambda Python code
- SNS alert email screenshot

This task will help you understand **API Gateway internals, security controls, monitoring, and production-grade automation practices** used in real cloud environments.

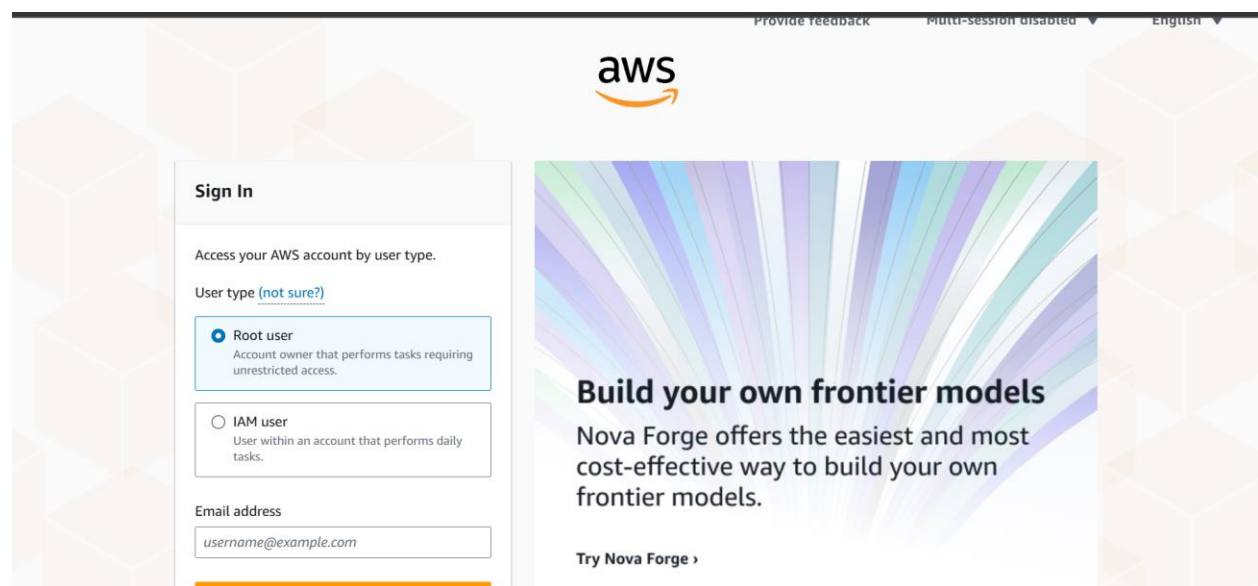
SOLUTION:

Secure, Monitor & Auto-Detect Abnormal Usage in AWS API Gateway

Login to your AWS account with credentials and required verification.

(<https://signin.aws.amazon.com/>)

My account – AWS Management Console- Sign in



1. Create Lambda Function (for Backend)
 - Go to AWS Console - Lambda - Create function
 - Choose:
 - Author from scratch

- Function name: api-backend-handler
- Runtime: Python 3.10
- Click Create function

The screenshot shows the AWS Lambda console interface. At the top, there's a navigation bar with services like Lambda, EC2, VPC, and IAM. Below this is a hero section for AWS Lambda with the text "lets you run code without thinking about servers." and a "Create a function" button. A "How it works" section shows a code editor with a Node.js example. The main part of the screenshot is the "Create function" wizard. It has three tabs: "Author from scratch" (selected), "Use a blueprint", and "Container image". Under "Author from scratch", there's a "Basic information" section with fields for "Function name" (api-backend-handler), "Runtime" (Python 3.10), and "Architecture" (x86_64). There's also a "Durable execution" section with an "Enable" checkbox.

Compute

AWS Lambda

lets you run code without thinking about servers.

You pay only for the compute time that you consume — there is no charge when your code is not running. With Lambda, you can run code for virtually any type of application or backend service, all with zero administration.

Get started

Author a Lambda function from scratch, or choose from one of many preconfigured examples.

[Create a function](#)

How it works [Run](#) [Next: Lambda responds to events](#)

.NET [Java](#) [Node.js](#) [Python](#) [Ruby](#) [Custom runtime](#)

```
1 * exports.handler = async (event) => {
2   console.log(event);
3   return 'Hello from Lambda!';
4 };
5
```

[CloudShell](#) [Feedback](#) [Console Mobile App](#) © 2026, Amazon Web Services, Inc. or its affiliates. [Privacy](#) [Terms](#) [Cookie preferences](#)

Create function [Info](#)

Choose one of the following options to create your function.

☒ **Author from scratch**
Start with a simple Hello World example.

☐ **Use a blueprint**
Build a Lambda application from sample code and configuration presets for common use cases.

☐ **Container image**
Select a container image to deploy for your function.

Basic information

Function name
Enter a name that describes the purpose of your function.

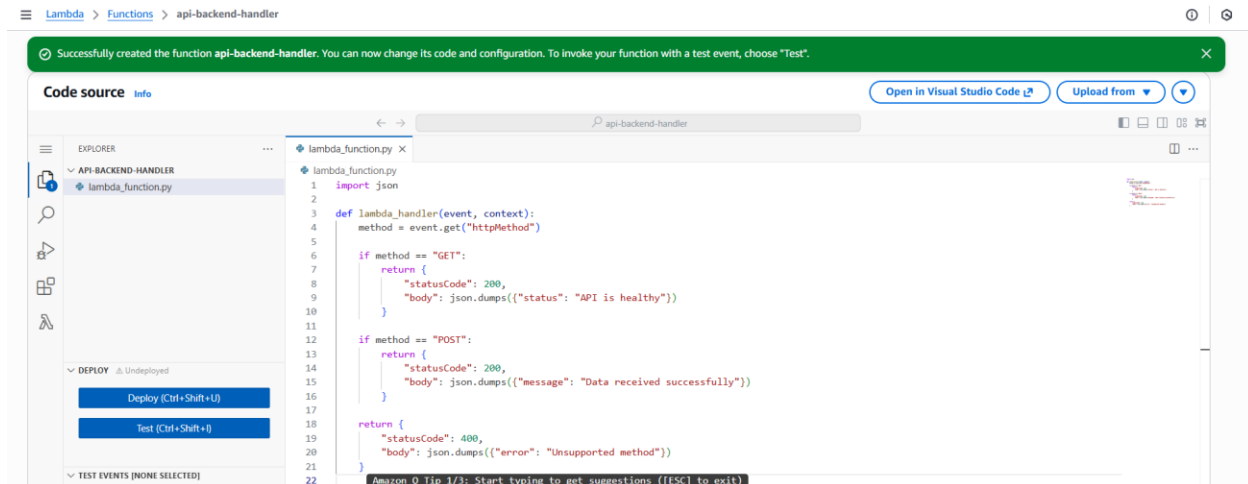
Function name must be 1 to 64 characters, must be unique to the Region, and can't include spaces. Valid characters are a-z, A-Z, 0-9, hyphens (-), and underscores (_).

Runtime [Info](#)
Choose the language to use to write your function. Note that the console code editor supports only Node.js, Python, and Ruby.
 [Last fetched 1/28/2026, 11:11:56 AM](#)

Durable execution - new [Info](#)
Enable durable execution to simplify building resilient multi-step applications that checkpoint progress and resume after interruptions. Supports Python and Node.js runtimes. [View pricing](#).
☐ Enable

Architecture [Info](#)
Choose the instruction set architecture you want for your function code.
☐ arm64
☒ x86_64

Deploy Lambda code



2. Create API Gateway REST API

- Go to API Gateway - Create API
- Choose REST API
- API name: SecureMonitoringAPI
- Endpoint type: Regional
- Click Create API

Create REST API

API details

☒ **New API**
Create a new REST API.

☐ **Clone existing API**
Create a copy of an API in this AWS account.

☐ **Import API**
Import an API from an OpenAPI definition.

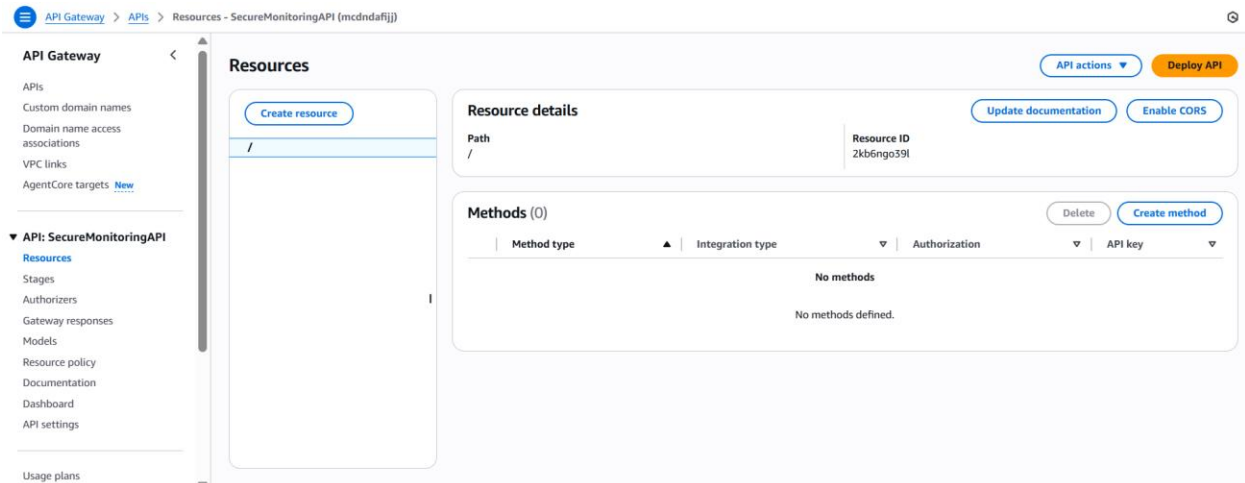
☐ **Example API**
Learn about API Gateway with an example API.

API name
SecureMonitoringAPI

Description - optional
Performance of Task 15

API endpoint type
Regional APIs are deployed in the current AWS Region. Edge-optimized APIs route requests to the nearest CloudFront Point of Presence. Private APIs are only accessible from VPCs.
Regional

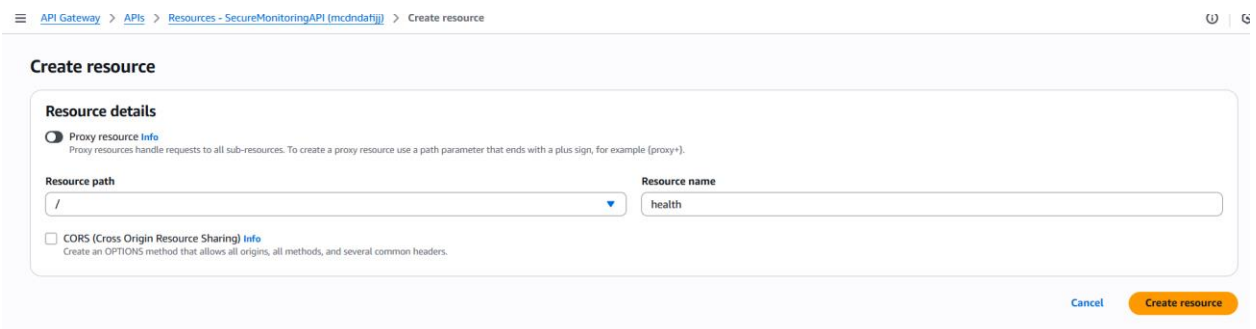
Security policy - new | Info
Transport Layer Security (TLS) protects data in transit between a client and server. The security policy also determines the cipher suite options that clients can use with your API.
Choose a security policy



Create Resources & Methods

/health Endpoint

- Resources - Create Resource
 - Resource Name: health
- Create GET Method
 - Integration type: Lambda Function
- Lambda function: api-backend-handler
 - Enable Lambda proxy integration



API Gateway
>
APIs
>
Resources - SecureMonitoringAPI (mcdndafiji)
>
Create method

Method type
GET

Integration type

☒
Lambda function
Integrate your API with a Lambda function.

☐
HTTP
Integrate with an existing HTTP endpoint.

☐
Mock
Generate a response based on API Gateway mappings and transformations.

☐
AWS service
Integrate with an AWS Service.

☐
VPC link
Integrate with a resource that isn't accessible over the public internet.

☒
Lambda proxy integration
Send the request to your Lambda function as a structured event.

Response transfer mode

☒
Buffered
Wait to receive the complete response before beginning transmission.

☐
Stream
Send portions of the response without waiting for the complete response.

Lambda function
Provide the Lambda function name or alias. You can also provide an ARN from another account.

us-east-1

arn:aws:lambda:us-east-1:798974631771:function:api-backend-hand

☐
Lambda proxy integration
Send the request to your Lambda function as a structured event.

Response transfer mode

☐
Buffered
Wait to receive the complete response before beginning transmission.

☐
Stream
Send portions of the response without waiting for the complete response.

You can only change the response transfer mode for proxy integrations.

Lambda function
Provide the Lambda function name or alias. You can also provide an ARN from another account.

us-east-1

arn:aws:lambda:us-east-1:798974631771:function:api-backend-hand

Grant API Gateway permission to invoke your Lambda function
When you save your changes, API Gateway updates your Lambda function's resource-based policy to allow this API to invoke it.

Integration timeout
By default, you can enter an integration timeout of 50 - 29,000 milliseconds. You can use Service Quotas to raise the integration timeout to greater than 29,000 ms

29000

Method request settings

/data Endpoint

- Create Resource - data
- Create POST Method
- Integration type: Lambda Function
- Lambda function: api-backend-handler

API Gateway
>
APIs
>
Resources - SecureMonitoringAPI (mcdndafiji)
>
Create resource

Create resource

Resource details

☐
Proxy resource
Proxy resources handle requests to all sub-resources. To create a proxy resource use a path parameter that ends with a plus sign, for example {proxy+}.

Resource path
/

Resource name
data

☐
CORS (Cross Origin Resource Sharing)
Create an OPTIONS method that allows all origins, all methods, and several common headers.

Cancel
Create resource

POST

Integration type

- ☒ **Lambda function**
Integrate your API with a Lambda function.
- ☐ HTTP
Integrate with an existing HTTP endpoint.
- ☐ Mock
Generate a response based on API Gateway mappings and transformations.
- ☐ AWS service
Integrate with an AWS Service.
- ☐ VPC link
Integrate with a resource that isn't accessible over the public internet.

☒ **Lambda proxy integration**
Send the request to your Lambda function as a structured event.

Response transfer mode | Info

- ☒ **Buffered**
Wait to receive the complete response before beginning transmission.
- ☐ Stream
Send portions of the response without waiting for the complete response.

Lambda function
Provide the Lambda function name or alias. You can also provide an ARN from another account.

us-east-1

Deploy API

Actions - Deploy API

Stage name: Prod

Deploy API

Create or select a stage where your API will be deployed. You can use the deployment history to revert or change the active deployment for a stage. [Learn more](#)

Stage
New stage

Stage name
prod

☒ A new stage will be created with the default settings. Edit your stage settings on the **Stage** page.

Deployment description
Deploying API

Cancel Deploy

3. Secure API

- Open POST /data
- Method Request
 - API Key Required → true
- Save

- Create API Key

API Gateway - API Keys - Create

- Name: SecureAPIKey

API Gateway > API keys > Create API key

Create API key [Info](#)

API key details

Name

Description - optional

API key

☒ Auto generate

☐ Custom

[Cancel](#) [Save](#)

Create Usage Plan

- Usage Plans - Create
- Name: SecureUsagePlan
- Throttle:
 - Rate: 5 requests/sec
 - Burst: 10
- Quota:
 - 1000 requests/day
- Associate:
 - API: SecureMonitoringAPI
 - Stage: prod
- Attach API Key

API Gateway > Usage plan > Create usage plan

Usage plan details

Usage plans specify the number or rate of requests that your API accepts from a client. Associate an API key with a usage plan to track the requests your API receives.

Name
SecureUsagePlan

Description - optional

☒ **Throttling**
Limit the rate that users can call your API.

Rate
05

Burst
10

☒ **Quota**
Turn on quotas to limit the number of requests a user can make to your API in a given time period.

Requests
Enter the total number of requests that a user can make in the time period you select in the dropdown list.
0200

Per day

API Gateway > Usage plans > SecureUsagePlan > Associate stage

Associate stage Info

Stage details

API
SecureMonitoringAPI

Stage
prod

You must select an API before selecting a stage.

► **Method-level throttling - optional**

Cancel Add to usage plan

API Gateway > Usage plans > SecureUsagePlan > Add API key

Successfully added stage "prod" to usage plan.

Add API key

API key details

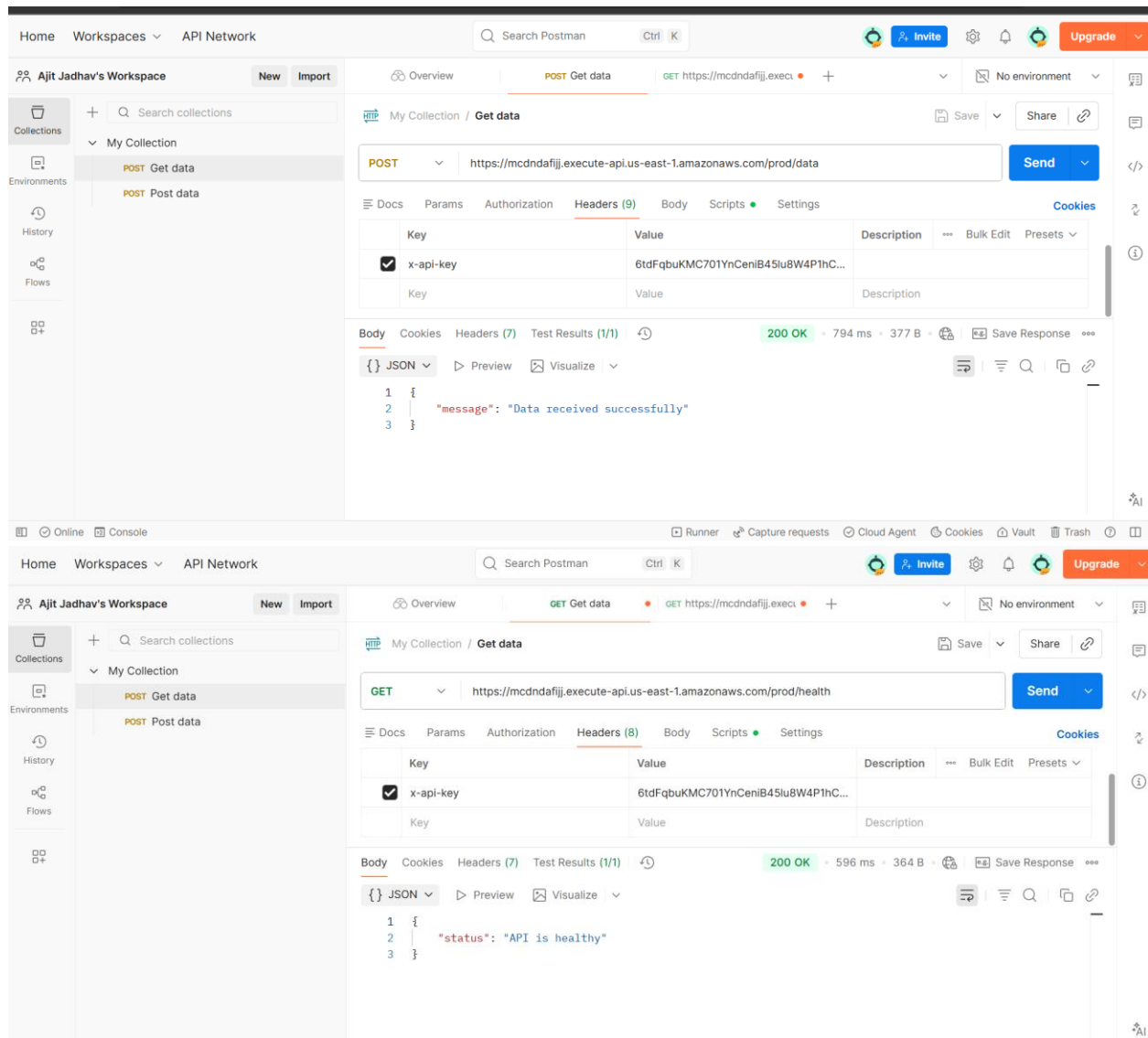
Type
☒ Add existing key
☐ Create and add new key

API key
SecureAPIKey

Cancel Add API key

4. Throttling & Rate Limiting

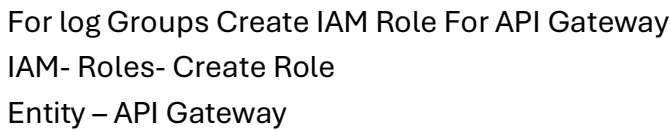
Login to your Postman account
and connect your API to it.



Now throttle

If you'll see:

- 429 Too Many Requests
- Confirms throttling works



IAM > Roles > Create role

```

12  {
13    "Action": [
14      "sts:AssumeRole"
15    ]
16  }
17 }

```

Step 2: Add permissions [Edit](#)

Permissions policy summary

Policy name	Type	Attached as
AmazonAPIGatewayPushToCloudWatchLogs	AWS managed	Permissions policy

Step 3: Add tags

Add tags - optional [info](#)

Tags are key-value pairs that you can add to AWS resources to help identify, organize, or search for resources.

No tags associated with the resource.

[Add new tag](#)

You can add up to 50 more tags.

[Cancel](#) [Previous](#) [Create role](#)

Attach role to API Gateway

and create Log Group
for storing Logs

CloudWatch > Log management > Create log group

CloudWatch

Log group details [info](#)

CloudWatch Logs offers three log classes: Standard, Infrequent Access, and Delivery. [Learn more about the features offered by each log class.](#)

Log group name

APIGateway

Retention setting

Never expire

Log class [info](#)

Standard

KMS key ARN - optional

☐ **Deletion protection**

Deletion protection is turned off by default. Deletion protection helps prevent accidental or unintended deletion of log groups that store critical operational or compliance data.

5. Enable Logging & Monitoring

Enable CloudWatch Logs

- API Gateway - Stages - prod
- Logs/Tracing:
 - Enable Execution logs
 - Log level: INFO
 - Enable Access logs
- Access Log Format:

Paste Log Group ARN and

```
{ "requestId": "$context.requestId", "ip": "$context.identity.sourceIp", "method": "$context.httpMethod", "path": "$context.resourcePath", "status": "$context.status", "latency": "$context.responseLatency" }
```

This Code

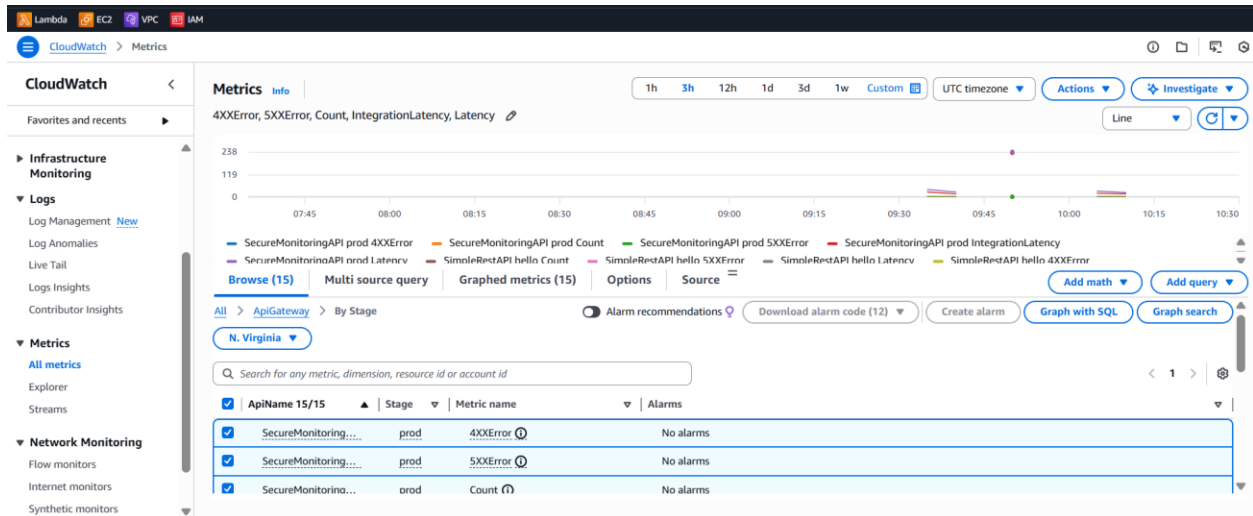
The image consists of two screenshots from the AWS Management Console.

The top screenshot shows the "Logs and tracing settings" for an API Gateway stage. The "Access log destination ARN" field is populated with "arn:aws:logs:us-east-1:798974631771:log-group:/aws/apigateway/welcome". The "Log format" section shows a JSON template for the logs.

```
1 {
2   "requestId": "$context.requestId",
3   "ip": "$context.identity.sourceIp",
4   "method": "$context.httpMethod",
5   "path": "$context.resourcePath",
6   "status": "$context.status",
7   "latency": "$context.responseLatency"
8 }
9
```

The bottom screenshot shows the "CloudWatch Metrics" console. The "Metrics" section is active, and a list of metrics is displayed. The "ApiGateway" metric is highlighted with a red box, showing a value of 39. Other metrics include CloudWatch/MetricStreams (30), EBS (45), EC2 (66), Firehose (280), KMS (5), Lambda (830), and Location (4).

Metric	Value
ApiGateway	39
CloudWatch/MetricStreams	30
EBS	45
EC2	66
Firehose	280
KMS	5
Lambda	830
Location	4



6. SNS Email Notification

- SNS - Topics - Create
- Type: Standard
- Name: API-Abuse-Alerts

Amazon SNS > Topics > Create topic

Create topic

Details

Type: **Standard**

Topic type cannot be modified after topic is created

☐ FIFO (first-in, first-out)

- Strictly-preserved message ordering
- Exactly-once message delivery
- Subscription protocols: SQS

☒ Standard

- Best-effort message ordering
- At-least-once message delivery
- Subscription protocols: SQS, Lambda, Data Firehose, HTTP, SMS, email, mobile application endpoints

Name

API-Abuse-Alerts

Maximum 256 characters. Can include alphanumeric characters, hyphens (-) and underscores (_).

Display name - optional

To use this topic with SMS subscriptions, enter a display name. Only the first 10 characters are displayed in an SMS message.

My Topic

Maximum 100 characters.

Encryption - optional

Amazon SNS provides in-transit encryption by default. Enabling server-side encryption adds at-rest encryption to your topic.

Create Subscription

Amazon SNS > Subscriptions > Create subscription

Topic ARN

Protocol
 The type of endpoint to subscribe

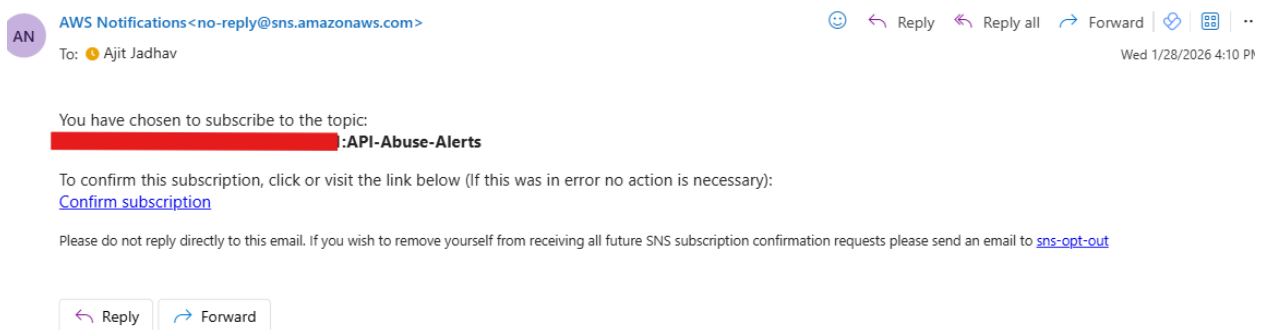
Endpoint
 An email address that can receive notifications from Amazon SNS.

After your subscription is created, you must confirm it. [Info](#)

► **Subscription filter policy - optional** [Info](#)
 This policy filters the messages that a subscriber receives.

► **Redrive policy (dead-letter queue) - optional** [Info](#)
 Send undeliverable messages to a dead-letter queue.

[Cancel](#) [Create subscription](#)



7. Abnormal Activity Detection Lambda

Monitoring Lambda

- Lambda - Create function
 - Name: api-monitor-lambda
 - Runtime: Python 3.9
- Add permissions:
 - *CloudWatchReadOnlyAccess*
 - *AmazonSNSFullAccess*

Lambda Code

Create function [Info](#)

Choose one of the following options to create your function.

- ☒ **Author from scratch**
Start with a simple Hello World example.
- ☐ **Use a blueprint**
Build a Lambda application from sample code and configuration presets for common use cases.
- ☐ **Container image**
Select a container image to deploy for your function.

Basic information

Function name
Enter a name that describes the purpose of your function.

Function name must be 1 to 64 characters, must be unique to the Region, and can't include spaces. Valid characters are a-z, A-Z, 0-9, hyphens (-), and underscores (_).

Runtime [Info](#)
Choose the language to use to write your function. Note that the console code editor supports only Node.js, Python, and Ruby.
 [Last fetched 1/28/2026, 4:14:56 PM](#)

Durable execution - new [Info](#)
Enable durable execution to simplify building resilient multi-step applications that checkpoint progress and resume after interruptions. Supports Python and Node.js runtimes. [View pricing](#).
☐ Enable

Architecture [Info](#)
Choose the instruction set architecture you want for your function code.
☐ arm64
☒ x86_64

Permissions [Info](#)
By default, Lambda will create an execution role with permissions to upload logs to Amazon CloudWatch Logs. You can customize this default role later when adding triggers.

▼ Change default execution role

Execution role
Choose a role that defines the permissions of your function. To create a custom role, go to the [IAM console](#).
☐ Create a new role with basic Lambda permissions
☒ Use an existing role
☐ Create a new role from AWS policy templates

Existing role
Choose an existing role that you've created to be used with this Lambda function. The role must have permission to upload logs to Amazon CloudWatch Logs.
 [View the hello-api-role-f5lz6g3k role](#) on the IAM console.

Successfully updated the function api-monitor-lambda.

Function URL [Info](#)
-

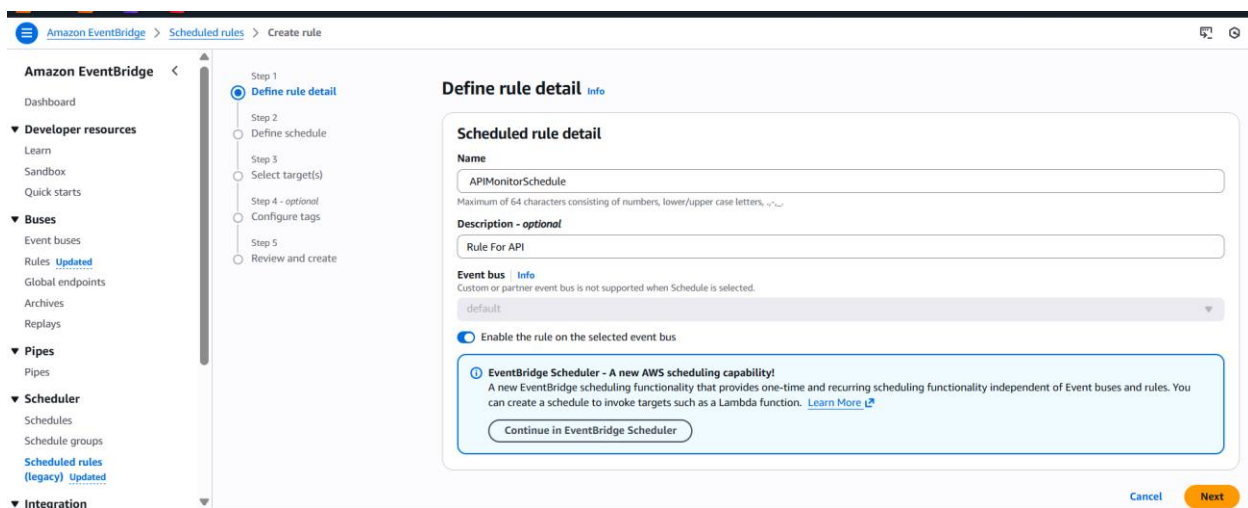
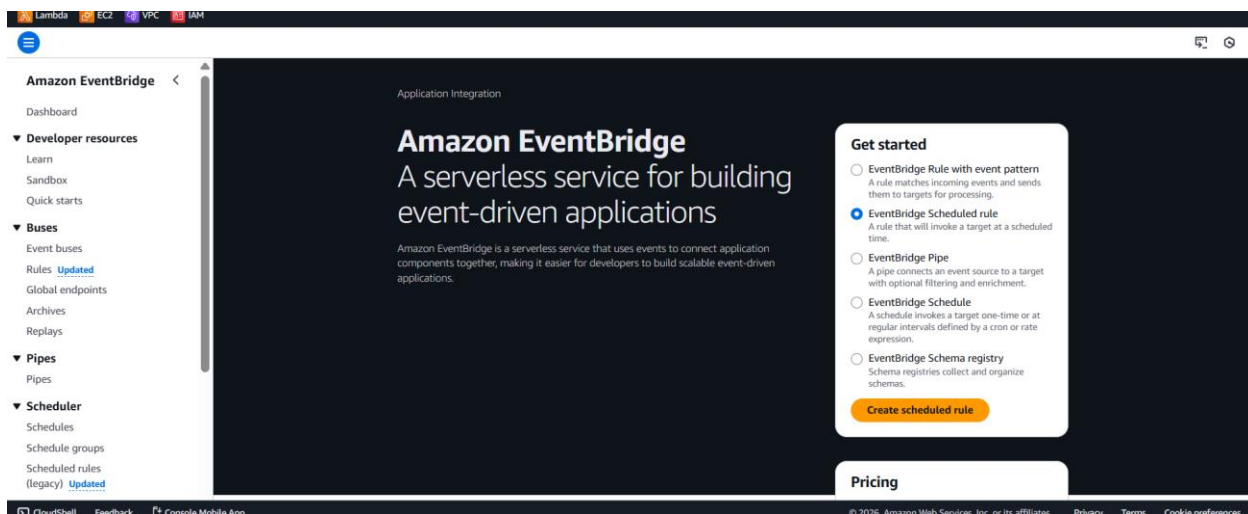
Code source [Info](#)

[Open in Visual Studio Code](#) [Upload from](#)

```
1 import boto3
2 from datetime import datetime, timedelta
3
4 cloudwatch = boto3.client('cloudwatch')
5 sns = boto3.client('sns')
6
7 SNS_TOPIC_ARN = "arn:aws:sns:us-east-1:798974631771:API-Abuse-Alerts"
8 API_NAME = "SecureMonitoringAPI"
9
10 def lambda_handler(event, context):
11     end = datetime.utcnow()
12     start = end - timedelta(minutes=15)
13
```

8. Schedule Lambda

- EventBridge - Create Rule
- Name: APIMonitorSchedule
- Schedule:
- Rate: 5 minutes
- Target:
- Lambda - api-monitor-lambda
- Enable rule



Amazon EventBridge

Scheduled rules

Create rule

Amazon EventBridge

Dashboard

Developer resources

Buses

Pipes

Scheduler

Integration

Step 1

Define rule detail

Step 2

Define schedule

Step 3

Select target(s)

Step 4 - optional

Configure tags

Step 5

Review and create

Define schedule

Schedule pattern

Schedule pattern

Choose the schedule type that best meets your needs.

☐ A fine-grained schedule that runs at a specific time, such as 8:00 a.m. PST on the first Monday of every month.
☒ A schedule that runs at a regular rate, such as every 10 minutes.

Rate expression

Info

Enter a value and the unit of time to run the schedule.

rate (

5

Minutes

)

Value

Unit, e.g. mins, hours...

Cancel

Previous

Next

Amazon EventBridge

Scheduled rules

Create rule

Amazon EventBridge

Dashboard

Developer resources

Buses

Pipes

Scheduler

Integration

Step 4 - optional

Configure tags

Step 5

Review and create

Target 1

Target types

Select an EventBridge event bus, EventBridge API destination (SaaS partner), or another AWS service as a target.

☐ EventBridge event bus
☐ EventBridge API destination
☒ AWS service

Select a target

Info

Select target(s) to invoke when an event matches your event pattern or when schedule is triggered (limit of 5 targets per rule)

Lambda function

Target location

☒ Target in this account
☐ Target in another AWS account

Function

api-monitor-lambda

Configure version/alias

Permissions

Use execution role (recommended)

Execution role

EventBridge needs permission to send events to the target specified above. By continuing, you are allowing us to do so. EventBridge and AWS identity and Access Management

☒ Create a new role for this specific resource
☐ Use existing role

Role name

RESULT

We have detected a high traffic and got Alert

AN

AWS Notifications<no-reply@sns.amazonaws.com>

To: Ajit Jadhav

Reply Reply all Forward ...

Wed 1/28/2026 5:22 PM

API: SecureMonitoringAPI
Metric Breached: High traffic or error rate
Requests: 54.0
Errors: 38.0
Time: 2026-01-28 11:52:13.971298

Suggested Action:
Check API logs, verify API key abuse, review throttling rules.

--

If you wish to stop receiving notifications from this topic, please click or visit the link below to unsubscribe:
[https://sns.us-east-1.amazonaws.com/unsubscribe.html?SubscriptionArn=\[REDACTED\]:API-Abuse-Alerts:1d75b83a-0860-431b-b2dd-49f0536acda7&Endpoint=ajit.jadhav@acc.ltd](https://sns.us-east-1.amazonaws.com/unsubscribe.html?SubscriptionArn=[REDACTED]:API-Abuse-Alerts:1d75b83a-0860-431b-b2dd-49f0536acda7&Endpoint=ajit.jadhav@acc.ltd)

Please do not reply directly to this email. If you have any questions or comments regarding this email, please contact us at <https://aws.amazon.com/support>

Reply

Forward

AN

AWS Notifications<no-reply@sns.amazonaws.com>

To: Ajit Jadhav

Reply Reply all Forward ...

Wed 1/28/2026 5:32 PM

API: SecureMonitoringAPI
Metric Breached: High traffic or error rate
Requests: 100.0
Errors: 70.0
Time: 2026-01-28 12:02:14.081100

Suggested Action:
Check API logs, verify API key abuse, review throttling rules.

--

If you wish to stop receiving notifications from this topic, please click or visit the link below to unsubscribe:
[https://sns.us-east-1.amazonaws.com/unsubscribe.html?SubscriptionArn=\[REDACTED\]:API-Abuse-Alerts:1d75b83a-0860-431b-b2dd-49f0536acda7&Endpoint=ajit.jadhav@acc.ltd](https://sns.us-east-1.amazonaws.com/unsubscribe.html?SubscriptionArn=[REDACTED]:API-Abuse-Alerts:1d75b83a-0860-431b-b2dd-49f0536acda7&Endpoint=ajit.jadhav@acc.ltd)

Please do not reply directly to this email. If you have any questions or comments regarding this email, please contact us at <https://aws.amazon.com/support>

Reply

Forward

Purpose: Understanding API Gateway internals, security controls, monitoring, and production-grade automation practices used in real cloud environments.
